ТЕХНИЧЕСКИ УНИВЕРСИТЕТ – СОФИЯ

ФАКУЛТЕТ КОМПЮТЪРНИ СИСТЕМИ И ТЕХНОЛОГИИ

Курсова Работа

***Дисциплина*:**

“Сигурност в безжичните мрежи”

***Тема*:**

“Атаки тип (Man-In-The-Middle) в Wi-Fi мрежи и методи за защита”

Изготвил: **Валентин Цонков**

Фак: 381222021

Група: 91а, 7 Курс, Ксиг

Email: vtsonkov@tu-sofia.bg

Ръководител: доц. Георги Балабанов

Дата: 01.12.2025г.

СЪДЪРЖАНИЕ	
Увод	стр. 3
Какво представлява атаката “Man-In-The-Middle”	стр. 4
Уязвимости в Wi-Fi мрежи, които позволяват MITM атаки	стр. 5
Методи за защита срещу MITM атаки в Wi-Fi мрежи	стр. 7
Заключение	стр. 13
Източници	стр. 13

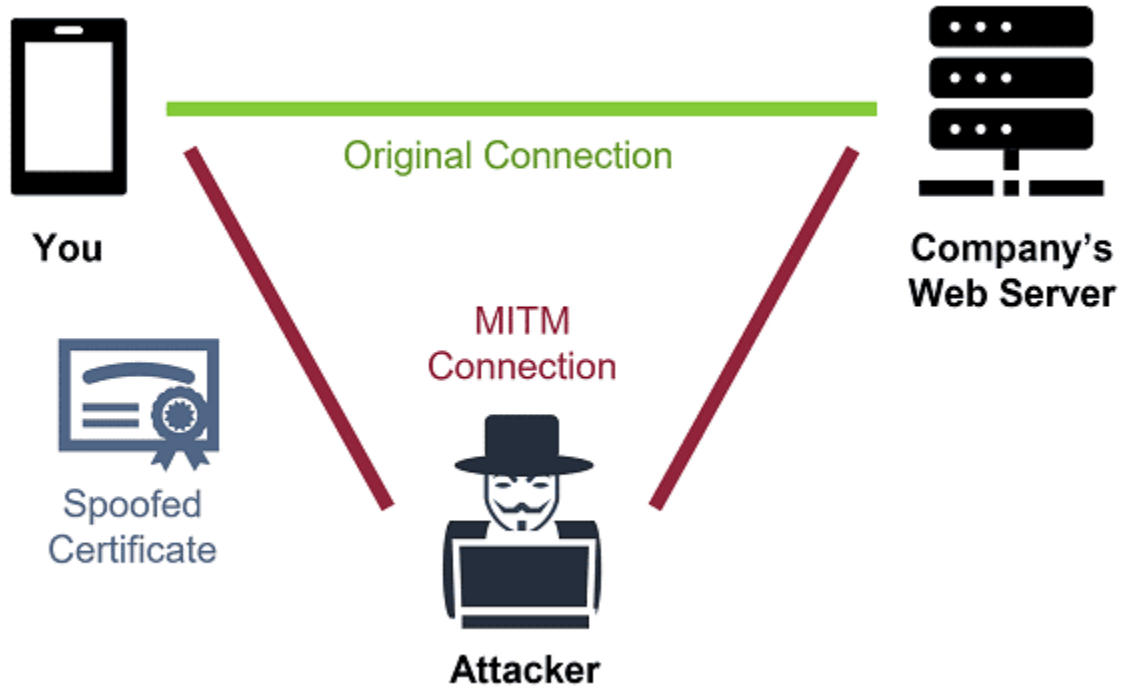
Увод:

В съвременната дигитална среда Wi-Fi мрежите са основен инструмент за достъп до интернет както в домашни условия, така и в публични пространства. Масовото им използване и отворената природа на радиокомуникацията ги правят особено уязвими към различни типове кибератаки. Сред най-разпространените и опасни е т.нар. Man-in-the-Middle (MITM), при която атакуващият тайно се позиционира между две комуникиращи страни, с цел да прихваща, пренасочва или манипулира предаваната информация.

MITM атаките в Wi-Fi мрежи често се реализират чрез техники като фалшиви точки за достъп (Evil Twin), ARP spoofing, DNS spoofing и SSL stripping. Отворените мрежи, слабите или остарели протоколи за криптиране, както и липсата на аутентикация на точките за достъп значително увеличават риска.

Целта на настоящата курсова работа е да анализира уязвимостите в Wi-Fi мрежите, които позволяват MITM атаки, и да представи ефективни методи за защита. Чрез преглед на реални техники за атака и съвременни механизми за защита се създава цялостен поглед върху начините за повишаване на сигурността в Wi-Fi среда.

Какво представлява атаката “Man-In-The-Middle”



(MITM) е тип кибератака, при която зловреден участник тайно се намесва в комуникацията между две страни (напр. клиент и сървър), за да прихваща, подслушва, променя или подправя информацията, която се предава между тях. Атакуващият се позиционира "в средата" на комуникационния канал, без знанието на участващите страни.

Уязвимости в Wi-Fi мрежи, които позволяват MITM атаки

Wi-Fi мрежите са особено податливи на MITM атаки заради безжичната си природа и недостатъците в някои версии на IEEE 802.11 протокола.

Ключови уязвимости, които могат да доведат до успешна MITM атака:

1. **Отворени Wi-Fi мрежи (без криптиране)**

   Липсата на парола означава липса на криптиране, което позволява на атакуващия да прихваща целия трафик. Това прави MITM атаки като SSL stripping и packet sniffing лесни за изпълнение.

2. **Слаби или остарели протоколи(WEP, WPA, WPA2 без PMF)**
   - **WEP (Wired Equivalent Privacy):** Лесно уязвим поради недостатъците в криптографските алгоритми, което позволява на нападателя да пробие мрежата за минути.

   - **WPA/WPA2-PSK (Wi-Fi Protected Access):** Уязвим при атаки с dictionary, brute force върху PSK (Pre-Shared Key) и прихващане на 4-way handshake-а.

   - **Липса на PMF (Protected Management Frames):** Позволява deauthentication атаки, които се използват за rogue AP/MITM.

3. **Липса на аутентификация на точките за достъп (Evil Twin)**
   - Устройства често се свързват автоматично към познати мрежи, без да проверяват легитимността на точката за достъп, заради това атакуващите, често използват метода (Evil Twin). Той представлява фалшива точка за достъп, Wi-Fi мрежа със същото име като легитимната, което подлъгва потребителите да се свържат към нея.

4. **Уязвимост в DNS конфигурацията**
   - **DNS Spoofing:** Ако DNS заявките не са защитени, атакуващият може да ги прихване и пренасочи жертвата към фалшиви уебсайтове. Липсата на DNSSEC (DNS Security Extensions) увеличава риска от подобни атаки.

5. **ARP Spoofing**
   - Протоколът ARP (Address Resolution Protocol) няма вградена защита, което позволява на атакуващите да изпращат фалшиви ARP отговори и да пренасочват трафика към себе си.

6. **SSL/TSL уязвимости**
   - **SSL Stripping:** Атакуващият пренасочва HTTPS заявка към HTTP версия, премахвайки защитата на връзката.
   - **Самоподписани или невалидни сертификати:** Потребителите често игнорират предупрежденията за невалидни SSL сертификати, което позволява на атакуващия да прихваща и декриптира трафика.

7. **Липса на мониторинг**
   - Много безжични мрежи не разполагат с инструменти за засичане на подозрителна активност като прихващане на пакети или ARP spoofing.

8. **Уязвимости в IoT устройства**
   - IoT устройства често имат слаба или липсваща защита, което ги прави лесни мишени за прихващане на данни и създаване на "входна точка" за MITM атака.

9. **Физически достъп до мрежата**
   - Ако нападателят има физически достъп до рутера, той може да манипулира настройките на мрежата и да прихваща трафика.

10. **KRACK (Key Reinstallation Attack)**
    - Уязвимост в WPA2 протокола, позволяваща повторно инсталиране на криптографски ключове по време на handshake-а.

11. **Captive Portal атаки**
    - В обществени мрежи с „логин портал“ атакуващите често използват фалшив portal за прихващане на пароли и сесии.

Методи за защита срещу MITM атаки в Wi-Fi мрежи

Ефективната защита срещу атаки тип Man-in-the-Middle в Wi-Fi мрежи изисква едновременно използване на криптографски механизми, протоколни защити, правилна конфигурация на точките за достъп, както и механизми за мониторинг и реакция. По-долу са разгледани подробно основните мерки и тяхното вътрешно функциониране.

Защита в Wi-Fi мрежи

1. Използване на силни криптографски методи

WPA2 – проблеми и ограничения
WPA2 използва:

- **4-стъпков handshake**
- **Pairwise Transient Key (PTK)**
- **Group Temporal Key (GTK)**

Основен проблем е, че handshake-ът може да бъде прихванат и използван за offline dictionary атаки. Липсата на PMF (IEEE 802.11w) позволява деавтентикационни атаки.

WPA3-SAE (Simultaneous Authentication of Equals)

WPA3 заменя PSK режима с протокола **SAE**, базиран на Dragonfly Key Exchange.

SAE защитата се състои от:

Стъпка 1: Commit Exchange

Клиентът и точката за достъп обменят "commit" съобщения, съдържащи:

- произволни стойности (nonces)
- елемент от групата (елиптична крива или модулна група)

Тези съобщения не позволяват възстановяване на паролата.

Стъпка 2: Confirm Exchange

Двете страни обменят MAC-подписани съобщения за потвърждение.

Така се гарантира:

- Взаимна аутентикация
- Защита срещу dictionary атаки
- Защита срещу brute-force
- Forward secrecy

Алгоритмична сила

SAE използва Diffie-Hellman обмен върху "hunting-and-pecking" алгоритъм → не позволява извличане на паролата чрез пасивно подслушване.

Protected Management Frames (PMF – IEEE 802.11w)

- Deauthentication
- Disassociation
- action frames

Това защитава мрежата от:

- Deauth атаки
- Тайно изключване на клиенти
- Rogue AP hijacking

PMF използва **AES-128 CCM** шифроване за защита на management frames.

2. Конфигурационни мерки на рутера

Деактивиране на WPS (Wi-Fi Protected Setup)
WPS е уязвим към brute-force на PIN кода (8 цифри → реално 7 + checksum). Алгоритъмът за проверка на PIN е разделен на две половини, което прави атаката още по-лесна.

Защитен подход:

- Изключване на WPS
- Използване само на WPA3-SAE

Филтриране на MAC адреси (ограничена, но валидна мярка)

Макар да може да бъде заобиколено чрез MAC spoofing, филтрирането:

- Намалява броя на потенциалните атакуващи
- Прави атаката по-трудоемка
- Позволява по-лесно засичане на аномалии

Регулярно сканиране за rogue AP

Точката за достъп извършва периодично пасивно и активно сканиране.

Активно сканиране: изпраща probe request

Пасивно: слуша beacon frames

Търсят се:

- Същия SSID, но различен BSSID
- Идентични параметри, но друг канал
- Аномални beacon интервали

3. Защита срещу Evil Twin атаки

WIDS (Wireless Intrusion Detection System)
WIDS засича:

- Фалшиви beacon frames
- Дублирани SSID
- Внезапна промяна на мощността на сигнала
- Деавтентикационни бури (внезапни вълни от deauth кадри)

Алгоритъмът често се базира на:

- Сигнатури (signature-based IDS)
- Аномалии (anomaly-based IDS)
- Времеви корелации между кадри

AP Authentication / 802.1X EAP-TLS

Клиентът може да изисква:

- Сертификат на точката за достъп
- TLS handshake
- Проверка на Root CA

Това прави невъзможно имитирането на корпоративни Wi-Fi мрежи.

4. Защита срещу ARP и DNS spoofing

Dynamic ARP Inspection (DAI)
DAI сравнява ARP трафика с **DHCP Snooping Binding Table**, в която AP/суичът поддържа информация:

- MAC
- IP
- VLAN
- Порт

Алгоритъм на DAI:

1. **Всеки ARP пакет се прихваща**
2. **Проверява се дали IP-MAC двойката е валидна**
3. **Невалидните пакети се отхвърлят**

Така ARP poisoning става невъзможен.

DNSSEC (DNS Security Extensions)

DNSSEC добавя цифрови подписи към DNS записите.

Алгоритъм:

- Заявката изисква DNSKEY
- Подписът (RRSIG) се валидира чрез публичния ключ
- Само при успех се връща отговор

Резултат:

- DNS spoofing не работи
- MITM чрез фалшиви сайтове е блокиран

5. VPN – крайно криптографска защита

VPN тунелира трафика чрез:

- AES-256
- ChaCha20
- DH/ECDH
- TLS 1.3

MITM става безсмислен, защото атакуващият вижда само шифровани пакети.

6. Добри потребителски практики

Проверка за HSTS (HTTP Strict Transport Security)
Браузърът отказва да зарежда HTTP версии на сайт, ако сайтът поддържа HSTS. Това прави SSL stripping атаки невъзможни.

Избягване на автоматично свързване към познати SSID
Това предотвратява Evil Twin имитации.

Редовни актуализации
Фърмуери на рутери често съдържат:

- Поправки по WPA
- Нови PMF имплементации
- Пачове срещу KRACK

Заключение

Wi-Fi мрежите са удобни и широко разпространени, но остават уязвими към Man-in-the-Middle атаки, ако не са правилно защитени. Основни рискове произтичат от остарели протоколи, липса на криптиране, фалшиви точки за достъп и манипулация на ARP или DNS трафика. Чрез използване на WPA3, PMF, IDS системи, надеждни DNS услуги и добри потребителски практики, рискът от MITM атаки може да бъде значително намален. Комбинацията от технически мерки и осведоменост е ключът към осигуряване на сигурна Wi-Fi комуникация.

Източници

- Wi-Fi Alliance – WPA3 Security Overview
  Линк: https://www.wi-fi.org/discover-wi-fi/security

- Wi-Fi Alliance – Protected Management Frames (PMF)
  Линк: https://www.wi-fi.org/discover-wi-fi/protected-management-frames

- IEEE 802.11 Standard
  Линк: https://standards.ieee.org/standard/802_11-2020.html

- IEEE Paper: Security Vulnerabilities in Wi-Fi Networks
  Линк: https://ieeexplore.ieee.org/document/9069227

- OWASP Man-in-the-Middle (MITM)
  Линк:https://owasp.org/www-community/attacks/Manipulator-in-the-middle_attack?utm_source=chatgpt.com

- OWASP TLS/SSL Security Guide
  Линк:https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html?utm_source=chatgpt.com